

CASE STUDY

DESIGNING A SECURE BLOCKCHAIN-BASED SUPPLY CHAIN MANAGEMENT SYSTEM

Name: Adhithyan S

Reg No: 192421102

Course Code: CSA5803

Course: DEVSECOPS ENGINEERING AND APPLICATION SECURITY

1. Executive Summary

Modern supply chains span dozens of independent organizations — raw-material suppliers, contract manufacturers, third-party logistics providers, distributors, retailers, and regulators — that rarely share a single trusted database. The result is fragmented visibility: paper certificates are forged, spreadsheets are edited after the fact, and a product recall can take weeks to trace back to its source. This case study designs and evaluates a secure, permissioned blockchain-based supply chain management (BSCM) system that gives every participant a shared, tamper-evident record of custody, condition, and provenance from origin to end consumer.

The proposed system combines a permissioned distributed ledger (modeled on Hyperledger Fabric), IoT-based sensing (RFID/NFC tags, environmental sensors, GPS), smart-contract-enforced business logic, and off-chain encrypted storage for bulky documents. It is designed against a formal STRIDE threat model covering three trust boundaries — the physical/edge layer, the blockchain core, and the application layer — with concrete mitigations mapped to each identified threat.

The remainder of this document presents the problem context, the four-layer reference architecture, the end-to-end operational workflow (including an exception/recall path), the full threat model with mitigations, an implementation and evaluation discussion grounded in a pharmaceutical cold-chain scenario, and a set of lessons learned and future directions.

2. Problem Statement and Background

2.1 Limitations of Traditional Supply Chain Systems

Traditional supply chain management relies on centralized databases (ERP/WMS systems) that are owned and controlled by a single organization. When goods cross organizational boundaries, the receiving party has no cryptographic way to

verify that the data it receives — a certificate of origin, a temperature log, a quality-inspection result — has not been altered in transit. This creates several structural weaknesses:

- Single point of failure and single point of trust: any one organization can unilaterally edit historical records.
- Data silos: each tier of the supply chain keeps its own records, making end-to-end traceability slow and manual.
- Counterfeiting and diversion: without a cryptographically unique, non-duplicable identity per batch or item, counterfeit goods can enter the chain undetected.
- Delayed recalls: without item-level provenance, a contamination event forces a full-category recall rather than a targeted one.
- Limited auditability for regulators: compliance audits depend on voluntarily shared, unverifiable paperwork.

2.2 Why Blockchain

A permissioned blockchain directly addresses these weaknesses by giving mutually distrustful organizations a shared ledger whose write access is governed by cryptographic identity and multi-party consensus rather than by any single administrator. Once a transaction (e.g., a custody transfer or a quality-check result) is endorsed by the required set of peer organizations and ordered into a block, it becomes computationally infeasible to alter without detection. This property — immutability under a decentralized trust model — is what a centralized database cannot offer, and it is the foundation on which the rest of this system's security guarantees are built.

2.3 Design Goals

1. Provenance integrity: every custody transfer and quality event is cryptographically signed and permanently recorded.
2. Confidentiality where required: commercially sensitive data (pricing, volumes) must not be visible to competitors on the same network.
3. Real-time visibility: authorized stakeholders can query current location and condition of any batch.
4. Automated compliance: smart contracts enforce business and regulatory rules (e.g., cold-chain thresholds) without manual intervention.
5. Resilience: the system must tolerate the failure or compromise of a minority of participating organizations.
6. Targeted recall capability: an anomaly must isolate only the affected batch, not the entire product line.

3. System Architecture

The system is organized into four layers, shown in Figure 1: a physical/IoT sensing layer, a permissioned blockchain and consensus layer, an application/API/integration layer, and the stakeholder layer representing the organizations that operate network nodes. Each layer has a distinct trust level, and data only moves upward after being cryptographically signed at its point of origin.

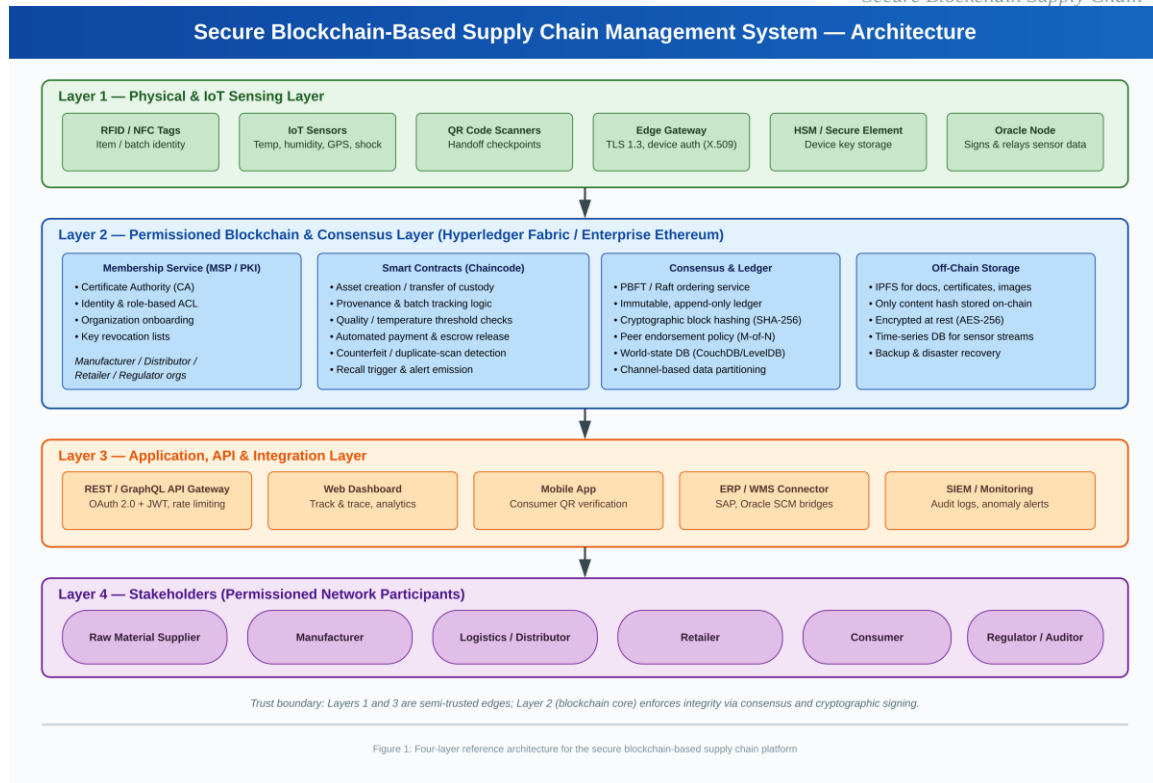


Figure 1. Four-layer reference architecture for the secure blockchain-based supply chain platform.

3.1 Layer 1 — Physical and IoT Sensing Layer

Each physical unit (pallet, case, or item, depending on granularity) is tagged with an RFID or NFC chip carrying a unique cryptographic asset identifier. Environmental sensors continuously capture temperature, humidity, GPS location, and shock/tilt events. Readings are signed locally using a key held in a hardware security module (HSM) or secure element before leaving the device, and are relayed through an edge gateway that authenticates itself to the network via a mutual-TLS, X.509-certificate-based handshake. An oracle node aggregates and re-signs sensor batches before submitting them as blockchain transactions, decoupling the trust-sensitive blockchain core from the more exposed physical edge.

3.2 Layer 2 — Permissioned Blockchain and Consensus Layer

This layer is the trust anchor of the system and is built on four components:

- **Membership Service Provider (MSP) / PKI** — issues and manages the X.509 identities of every organization and device on the network, and underpins all subsequent access control.
- **Smart contracts (chaincode)** — encode the business logic: asset creation, custody transfer, quality-threshold validation, escrow-based payment release, duplicate-scan / counterfeit detection, and recall triggers.
- **Consensus and ledger** — an ordering service (Raft or PBFT-style Byzantine fault-tolerant protocol) sequences transactions into cryptographically chained blocks, replicated across peer nodes according to an endorsement policy that requires sign-off from multiple, independent organizations before a transaction is committed.

- Off-chain storage — bulky artifacts (lab certificates, images, customs paperwork) are stored in an access-controlled, encrypted IPFS cluster; only their content hash is written to the ledger, keeping on-chain storage lean while preserving verifiability.

3.3 Layer 3 — Application, API, and Integration Layer

Stakeholders interact with the ledger indirectly through an API gateway that enforces OAuth 2.0 authentication, short-lived JWTs, and rate limiting. A web dashboard supports track-and-trace queries and analytics for internal staff; a mobile application allows end consumers to scan a product's QR code and view its full, read-only provenance history; and ERP/WMS connectors bridge the blockchain to each organization's existing enterprise systems. A SIEM (security information and event management) pipeline aggregates audit logs from every layer for anomaly detection and compliance reporting.

3.4 Layer 4 — Stakeholders

Six categories of participant operate as permissioned members of the consortium network: raw-material suppliers, manufacturers, logistics/distribution partners, retailers, consumers (read-only), and regulators/auditors (read access with query rights across organizational boundaries for compliance purposes).

4. End-to-End Operational Workflow

Figure 2 traces a single product batch through six on-chain checkpoints, from raw-material sourcing to consumer verification, and shows the automated exception path that activates when a monitored condition is breached.

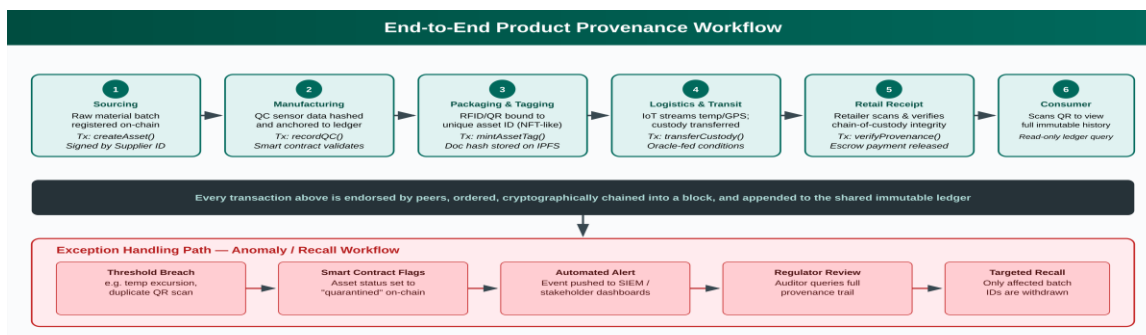


Figure 2: End-to-end custody workflow with on-chain transaction triggers and the automated exception / recall path

Figure 2. End-to-end custody workflow with on-chain transaction triggers and the automated exception/recall path.

4.1 Primary Flow

7. Sourcing — the raw-material supplier registers a new batch via createAsset(), cryptographically signed with the supplier's network identity, capturing origin, quantity, and initial certification hashes.
8. Manufacturing — quality-control sensor readings are hashed and anchored via recordQC(); the smart contract automatically validates results against predefined acceptance thresholds before allowing the batch to progress.

9. Packaging and tagging — a unique, non-duplicable asset identifier is minted and bound to the physical RFID/QR tag via `mintAssetTag()`; supporting documents are pushed to IPFS with only their hash recorded on-chain.
10. Logistics and transit — IoT devices stream temperature, humidity, and location data through the oracle layer; each hand-off between carriers executes `transferCustody()`, updating the immutable chain of custody.
11. Retail receipt — the receiving retailer calls `verifyProvenance()` to cryptographically confirm the batch's full history is unbroken and within tolerance before accepting delivery; smart-contract-managed escrow then automatically releases payment to the upstream party.
12. Consumer verification — the end consumer scans the product's QR code to run a read-only ledger query, viewing the complete, tamper-evident provenance trail from source to shelf.

Every transaction listed above is independently endorsed by the peer nodes specified in the relevant endorsement policy, ordered by the consensus service, cryptographically chained into a block using SHA-256 hashing, and appended to the ledger copy held by every participating organization — eliminating any single party's ability to retroactively alter history.

4.2 Exception Handling and Recall Path

When a monitored condition is breached — for example, a cold-chain temperature excursion or a duplicate scan of an asset identifier that should be unique — the smart contract automatically transitions the affected asset's on-chain status to quarantined. This event is pushed in real time to the SIEM pipeline and stakeholder dashboards, giving regulators and auditors the ability to query the complete provenance trail for the affected batch. Because every unit carries its own cryptographic identity, a recall can be scoped precisely to the affected batch identifiers rather than triggering a blanket withdrawal of an entire product line — materially reducing both cost and consumer impact.

5. Threat Model

The system was analyzed using the STRIDE methodology (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) across the three trust boundaries implied by the architecture: the untrusted physical/edge zone, the semi-trusted blockchain core operated jointly by consortium members, and the untrusted application/user zone at the network's outer edge. Figure 3 maps each identified threat to its target asset and corresponding mitigation.

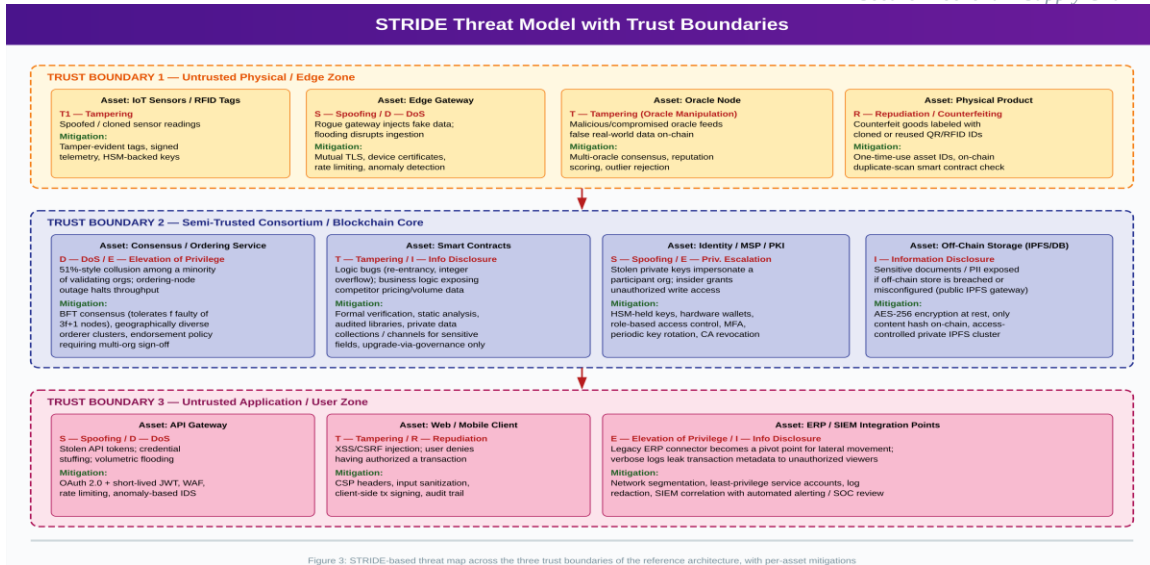


Figure 3: STRIDE-based threat map across the three trust boundaries of the reference architecture, with per-asset mitigations

Figure 3. STRIDE-based threat map across the three trust boundaries of the reference architecture, with per-asset mitigations.

5.1 Trust Boundary 1 — Physical / Edge Zone

Assets in this zone — sensors, tags, gateways, and oracle nodes — are the least defensible because they operate outside the cryptographic guarantees of the ledger itself. The principal risks are tampering with sensor readings, spoofed or flooding traffic against edge gateways, oracle manipulation (feeding false real-world data on-chain), and counterfeit goods carrying cloned identifiers. Mitigations combine tamper-evident hardware, HSM-backed signing keys, mutual TLS with certificate-based device authentication, multi-oracle consensus with outlier rejection, and smart-contract-enforced duplicate-scan detection.

5.2 Trust Boundary 2 — Blockchain Core

This is the system's trust anchor, and threats here have the widest blast radius. Key risks include collusion among a minority of validating organizations to disrupt consensus, smart-contract logic vulnerabilities (re-entrancy, integer overflow), unauthorized information disclosure of commercially sensitive data, and identity compromise through stolen private keys. The Byzantine-fault-tolerant consensus protocol tolerates up to f faulty nodes out of $3f+1$, so no minority coalition can unilaterally rewrite history; smart contracts undergo formal verification and static analysis prior to deployment and can only be upgraded through a defined governance process; sensitive fields are isolated using private data collections or channels; and identity keys are held in HSMs with periodic rotation and revocation support.

5.3 Trust Boundary 3 — Application / User Zone

The outermost layer — API gateways, web/mobile clients, and legacy ERP/SIEM integration points — is exposed to conventional web and enterprise-integration attack surfaces: credential stuffing, cross-site scripting, denial-of-service flooding, and lateral movement through poorly segmented legacy connectors. Mitigations rely on established application-security practice: OAuth 2.0 with short-lived JSON Web Tokens, a web-application firewall, rate limiting, content security policies, client-side transaction signing so users cannot repudiate authorized actions, network segmentation for legacy integrations, and continuous SIEM correlation with automated alerting.

5.4 Residual Risk

No architecture eliminates risk entirely. Residual exposure includes the possibility of a sufficiently large coalition of colluding consortium members exceeding the Byzantine fault tolerance threshold, compromise of a device's HSM at the point of manufacture (a supply-chain-of-the-supply-chain risk), and social-engineering attacks against individuals holding administrative key material. These risks are addressed operationally through governance policy (minimum organizational diversity requirements, background-checked key custodians) rather than through technical controls alone, and are reviewed in Section 8.

6. Applied Case Study: Pharmaceutical Cold-Chain Distribution

To ground the architecture in a concrete scenario, consider a temperature-sensitive vaccine distributed from a single manufacturing plant through a regional distributor to 40 retail pharmacies. Regulatory guidelines mandate that the product remain within 2°C–8°C at all times, and any excursion must trigger an investigation before the batch can be dispensed.

6.1 Scenario Walkthrough

Each vaccine carton is tagged with an NFC chip bearing a unique batch-and-serial identifier, and shipping pallets are fitted with IoT temperature loggers reporting every five minutes. At manufacturing, the batch is registered on-chain with its cold-chain tolerance encoded directly into the governing smart contract. During transit, the logistics provider's edge gateway relays signed temperature readings through the oracle layer; the smart contract continuously evaluates each reading against the 2°C–8°C threshold. On day two of transit, a refrigeration unit malfunction causes the temperature to rise to 11°C for eighteen minutes. The threshold-breach logic immediately sets the batch's on-chain status to quarantined, and an automated alert is pushed to the distributor, the manufacturer, and the regulatory dashboard within seconds of the breach being recorded.

Because every carton in the batch carries the same batch identifier but a distinct serial number, and because the quarantine flag is scoped to that specific batch, the other 39 pharmacies that had already received earlier, unaffected batches are unaffected — their inventory is not flagged, and no blanket recall is issued. The regulator, given standing read access to the ledger, independently verifies the full temperature history and the timing of the quarantine action without needing to request records from any single party.

6.2 Outcome Comparison

Dimension	Traditional Paper/ERP Process	Blockchain-Based System (This Design)
Detection time for excursion	Hours to days (manual log review)	Seconds (automated smart-contract check)
Recall scope	Entire product line / all batches shipped that week	Single, precisely identified batch

Dimension	Traditional Paper/ERP Process	Blockchain-Based System (This Design)
Cross-party verification	Requires manual data requests between organizations	Real-time, self-service ledger query
Audit trail integrity	Editable spreadsheets and PDFs	Cryptographically immutable, tamper-evident
Regulator access	Ad hoc, on request	Standing, read-only, real-time

Table 1. Outcome comparison between a traditional cold-chain process and the proposed blockchain-based system.

6.3 Performance and Scalability Considerations

A permissioned Byzantine-fault-tolerant ledger such as Hyperledger Fabric typically sustains several hundred to a few thousand transactions per second depending on endorsement-policy complexity, block size, and the number of participating organizations — sufficient for batch-level and pallet-level granularity, though item-level tagging at very high volume (e.g., individual consumer packaged goods) may require aggregation strategies such as Merkle-batching multiple sensor readings into a single on-chain transaction to control ledger growth. Off-chain storage of bulky documents keeps on-chain payloads small, and channel-based data partitioning allows the network to scale horizontally as new organizations join without every participant needing visibility into every other participant's private transactions.

7. Security Controls Summary

Table 2 consolidates the technical and governance controls referenced throughout this document, organized by security objective.

Security Objective	Primary Controls
Authentication & Identity	X.509 PKI / MSP, mutual TLS, HSM-backed keys, multi-factor authentication for administrative access
Data Integrity	Cryptographic transaction signing, SHA-256 block hashing, multi-organization endorsement policies
Confidentiality	AES-256 encryption at rest, private data collections / channels, encrypted off-chain IPFS storage
Availability	BFT consensus tolerant of f -of- $3f+1$ faulty nodes, geographically diverse orderer clusters, rate limiting
Non-repudiation	Client-side transaction signing, immutable append-only ledger, full audit logging

Security Objective	Primary Controls
Access Control	Role-based access control (RBAC), least-privilege service accounts, channel-based data partitioning
Monitoring & Response	SIEM correlation, automated anomaly alerting, smart-contract-triggered quarantine workflow

Table 2. Consolidated security controls mapped to core security objectives.

8. Lessons Learned and Future Directions

8.1 Lessons Learned

- Trust boundaries, not network boundaries, should drive the threat model — the weakest point in this system is the physical/edge layer, not the blockchain core, because sensors are the hardest component to secure against physical tampering.
- Smart-contract logic errors are a greater practical risk than consensus-layer attacks in a permissioned setting with a small, vetted set of validating organizations; formal verification and audited contract libraries deserve proportionally more investment than exotic consensus hardening.
- On-chain storage should be reserved for hashes and state transitions; bulky documents belong off-chain, with only their fingerprint anchored to the ledger.
- Governance — who can join the consortium, how keys are custodied, how contracts are upgraded — is as important to overall security as any cryptographic control.

8.2 Future Directions

- Zero-knowledge proofs to allow regulators to verify compliance (e.g., temperature stayed within range) without revealing the full underlying data stream to competitors on the same network.
- Cross-chain interoperability protocols to connect supply-chain consortia that have independently adopted different underlying blockchain platforms.
- Machine-learning-based anomaly detection layered on top of the SIEM pipeline to flag subtle, multi-signal fraud patterns that a single fixed threshold would miss.
- Post-quantum-resistant signature schemes for long-lived provenance records, given the multi-decade shelf life of some regulatory audit requirements.

9. Conclusion

This case study has presented a complete design for a secure, permissioned blockchain-based supply chain management system: a four-layer reference architecture, an end-to-end operational workflow with an automated exception/recall path, and a STRIDE-based threat model with concrete, layer-appropriate mitigations. Applied to a pharmaceutical cold-chain scenario, the design demonstrates measurable improvements over traditional paper- and ERP-based processes — near-

instant excursion detection, precisely scoped recalls, and real-time, self-service verification for every stakeholder including regulators. The system's security rests not on any single control but on the layered combination of cryptographic identity, Byzantine-fault-tolerant consensus, smart-contract-enforced business rules, and conventional application-security hygiene at the network's edges — an approach that generalizes beyond pharmaceuticals to food safety, luxury-goods anti-counterfeiting, and conflict-mineral provenance use cases.

References

- [1] P. Dudczyk, J. K. Dunston, and G. Crosby, “Blockchain Technology for Global Supply Chain Management: A Survey of Applications, Challenges, Opportunities and Implications,” *IEEE Access*, vol. 12, pp. 70065–70088, 2024, doi: 10.1109/ACCESS.2024.3399759.
- [2] A. Kumar et al., “Blockchain-Based Smart Contracts for Enhancing Supply Chain Transparency,” in *Proceedings of the 2024 International Conference on IoT, Communication and Automation Technology (ICICAT)*, IEEE, 2024, doi: 10.1109/ICICAT62666.2024.10923483.
- [3] M. Khatun and T. Darwish, “Unlocking Blockchain's Potential in Supply Chain Management: A Review of Challenges, Applications, and Emerging Solutions,” *Network*, vol. 5, no. 3, 2025, doi: 10.3390/network5030034.
- [4] Ö. Karaduman and G. Gülhas, “Blockchain-Enabled Supply Chain Management: A Review of Security, Traceability, and Data Integrity Amid the Evolving Systemic Demand,” *Applied Sciences*, vol. 15, no. 9, Art. 5168, 2025, doi: 10.3390/app15095168.
- [5] “Blockchain for Data Traceability: Ensuring Integrity in Digital Ecosystems,” in *Proceedings of the 2025 International Conference on Computational Intelligence Approaches and Applications (ICCIAA)*, IEEE, 2025, doi: 10.1109/ICCIAA65327.2025.11013507.
- [6] “Blockchain in Supply Chain Management: A Comprehensive Review of Success Measurement Methods,” *Management Review Quarterly*, Springer Nature, 2025.